

LAPORAN TUGAS ZTNA

LAS WEEK 2 (CS)

MBC LAB 2026



NAMA: MUHAMMAD ILYAS SYARIEF

ID CAAS: 2644

DAFTAR ISI

DAFTAR ISI.....	2
1.RINGKASAN.....	3
2.DIAGRAM ARSITEKTUR.....	3
3.RINGKASAN KONFIGURASI.....	4
4.BUKTI PENGUJIAN.....	6
5.JAWABAN PERTANYAAN ANALISIS.....	9
6.KENDALA & SOLUSI.....	13
7.KESIMPULAN.....	14
8.LAMPIRAN.....	14

1. Ringkasan

Laporan ini adalah hasil dokumentasi implementasi ZTNA dalam sebuah server menggunakan keycloak sebagai identity Provider dan OpenZiti sebagai Zero Trust Network overlay. Implementasi ini dilakukan menggunakan 4 VM Ubuntu Server dan menggunakan Host-Only Network di dalam konfigurasi jaringan nya agar semua VM dapat terhubung.

2. Diagram Arsitektur

Untuk konfigurasi jaringan dalam tugas ini terdiri atas host Windows, 4 VM pada jaringan host-only dengan rentang ip 192.168.234.0/24, dan ziti overlay network 100.64.0.0/10, dan diringkas pada tabel berikut.

Node	Peran	Alamat
Windows Host	Browser / SSH Client	192.168.234.0/24 (host network)
VM1 - ztna-server	Keycloak + OpenZiti Controller/Router, Web App, SSH, DB	192.168.234.101
VM2 - mahasiswa-client	ziti-edge-tunnel	192.168.234.102
VM3 - dosen-client	ziti-edge-tunnel	192.168.234.103
VM4 - admin-client	ziti-edge-tunnel	192.168.234.104
Ziti Controller	Kontrol overlay, port 1280	-
Edge Router	Data plane overlay, port 3022	-
Ziti Overlay Network	Jaringan virtual terenkripsi	100.64.0.0/10

Alur koneksi: client (vm2-v4) terhubung ke ziti overlay melalui mTLS, vm1 meneruskan autentikasi ke Keycloak melalui

OIDC, sedangkan Ziti Controller dan Edge Router saling terhubung melalui mTLS untuk meneruskan trafik menuju layanan yang ada di-host di vm1.

3. Ringkasan Konfigurasi

3.1 Keyloack (Identity Provider)

Parameter	Value
Realm	mbc-lab
URL	http://192.168.234.101:8080
OIDC Endpoint	http://ztna-server:8080/realms/mbc-lab

Users

Username	Role	Group	Faktor Autentikasi
mhs1	Mahasiswa	mahasiswa	Password (Single Factor)
dsn1	Dosen	dosen	Password + TOTP (2FA)
adm1	Admin	admin	Password + TOTP + Passkey (3FA)
gst1	Guest	guest	Password (Single Factor)

OIDC Clients

Client ID	Purpose
ziti-client	Ziti Controller OIDC Integration
ziti-edge-tunnel	Ziti Tunnel OIDC Auth
ziti-mhs / dsn / adm / gst	Client-specific OIDC

3.2 OpenZiti

Parameter	Value
Controller	https://ztna-server:1280
Edge Router	router-quickstart (online)
Overlay Network	100.64.0.0/10

Services

Service	Port	Protocol	Host Bind	Intercept
webapp	80	TCP	127.0.0.1:80	127.0.0.1:80
ssh	22	TCP	127.0.0.1:22	127.0.0.1:22
db	3306	TCP	127.0.0.1:3306	127.0.0.1:3306
ziti-dns-resolver	53	UDP	100.64.0.2:53	100.64.0.2:53

3.3 Services Policy

Dial Policy

Policy	Services	Identities	Semantic
dial.mhs	webapp	#mahasiswa	AnyOf
dial.dsn	ssh, webapp	#dosen	AnyOf
dial.adm	db, ssh, webapp	#admin	AnyOf
dial.gst	webapp	#guest	AnyOf
dial.dns-resolver	ziti-dns-resolver	#all	AnyOf

Bind Policy

Policy	Services	Identities
bind.web	db, ssh, webapp	#host
dns-resolver-bind	ziti-dns-resolver	#host

3.4 Identity & Auth Policy

Identity	Attributes	Auth Policy
user.mahasiswa	mahasiswa	Default
user.dosen	dosen	Default
user.admin	admin	Default
user.guest	guest	extjwt-only

Identity	Attributes	Auth Policy
vm1-host	host	Default

4. Bukti Pengujian

#1 : Status: BLOCKED (DNS Resolver) | Terminal: (VM2) | User: mahasiswa

```
mahasiswa@mahasiswa-client:~$ curl http://webapp.ziti
curl: (6) Could not resolve host: webapp.ziti
mahasiswa@mahasiswa-client:~$
```

Expected Output (jika DNS fixed):

```
<!DOCTYPE html>
```

```
<html>
```

```
<head><title>MBC Lab - Internal Web App</title></head>
```

```
<body><h1>MBC Lab - Internal Web App (Zero Trust)</h1><p>Halaman
ini hanya bisa diakses via Ziti.</p></body>
```

```
</html>
```

Actual Output (Current - BLOCKED):

```
curl: (6) Could not resolve host: webapp.ziti
```

#2 : Status: BLOCKED (DNS Resolver) | Terminal: (VM2) | User: mahasiswa

```
mahasiswa@mahasiswa-client:~$ ssh ztna@192.168.234.101
ssh: connect to host 192.168.234.101 port 22: Connection timed out
mahasiswa@mahasiswa-client:~$
```

Negative Test Analysis:

- Policy: dial.mhs hanya allow @webapp, TIDAK include @ssh
- Jika DNS fixed & SSH ditolak = PASS

- Jika DNS fixed & SSH connect = FAIL

#3 : Status: BLOCKED (DNS) | Terminal: (VM3) | User: dosen

syarat:

- Login Keycloak browser sebagai dsn1 / Admin123! TANPA TOTP

```
dosen@dosen-client:~$ curl http://webapp.ziti
curl: (6) Could not resolve host: webapp.ziti
dosen@dosen-client:~$ _
```

Negative Test Logic:

- Policy: dial.dsn allow @webapp + @ssh untuk #dosen
- Keycloak MFA: Dosen wajib TOTP (Required Action: Configure TOTP)
- Tanpa TOTP → Keycloak harus menolak / challenge MFA
- Jika DNS fixed & akses ditolak = PASS (Security OK)

#4 : Status: BLOCKED (DNS) | Terminal: T4 (VM3) | User: dosen

syarat:

- Login Keycloak browser sebagai dsn1 DENGAN TOTP (setup authenticator app)

```
dosen@dosen-client:~$ curl http://webapp.ziti
curl: (6) Could not resolve host: webapp.ziti
dosen@dosen-client:~$ ssh ztna@192.168.234.101
ssh: connect to host 192.168.234.101 port 22: Connection timed out
dosen@dosen-client:~$
```

#5 : Status: BLOCKED (DNS) | Terminal: (VM4) | User: admin

syarat:

- Login Keycloak browser sebagai adm1 TANPA TOTP/Passkey (hanya password)

```
adminn@admin-client:~$ curl http://ebapp.ziti
curl: (6) Could not resolve host: ebapp.ziti
adminn@admin-client:~$
```

#6 : Status: WORKING | Terminal: T1 (Windows), T3 (VM2) | Time: 2 min

Windows:

```
■ ilyas@HyperX ~ > ssh 192.168.234.101
ssh: connect to host 192.168.234.101 port 22: Connection refused
■ ilyas@HyperX ~ > |
```

VM2:

```
mahasiswa@mahasiswa-client:~$ ssh -o ConnectTimeout=5 192.168.234.101
ssh: connect to host 192.168.234.101 port 22: Connection timed out
mahasiswa@mahasiswa-client:~$
```

PASS Criteria: Semua timeout/refused.

#7 Policy Revocation Enforcement (WORKING)

```
ztna@ztna-server:~$ ziti edge login localhost:1280 -u admin -p admin
Token: adb046d5-7172-4812-950c-7e731f37f745
Saving identity 'default' to /home/ztna/.config/ziti/ziti-cli.json
ztna@ztna-server:~$ ziti edge delete service-policy dial.mhs
Found 0 service-policies with id or name matching dial.mhs
ztna@ztna-server:~$ ziti edge list service-policies
```

ID	NAME	TYPE	SEMANTIC	SERVICE ROLES	IDENTITY ROLES	POSTURE CHECK ROLES
24j6ywnpp1VRbXaz02M1N	dns-resolver-dial	Dial	AnyOf	#ziti:dns-resolver	#all	
3Q1jvixP5L2XnH79WL9YI4	dial.dsn	Dial	AnyOf	@ssh @webapp	#dosen	
5zvK8cicqI10Vpu0RtzQP1	dial.adm	Dial	AnyOf	@db @ssh @webapp	#admin	
76iaj2moQvu7EC0jd4XQEx	bind.web	Bind	AnyOf	@db @ssh @webapp	#host	
7I9y8OargvEBEH0gJUJQLR	dial.gst	Dial	AnyOf	@webapp	#guest	
U1kfBcb2PwPUsR5nLwa0F	dns-resolver-bind	Bind	AnyOf	#ziti:dns-resolver	#host	

```
results: 1-6 of 6
ztna@ztna-server:~$
```

```
ztna@ztna-server:~$ ziti edge policy-advisor identities user.mahasiswa webapp
```

Policy General Guidelines

- In order for an identity to dial or bind a service, the following must be true:
- The identity must have access to the service via a service policy of the correct type (dial or bind)
 - The identity must have access to at least one on-line edge router via an edge router policy
 - The service must have access to at least one on-line edge router via a service edge router policy
 - There must be at least one on-line edge router that both the identity and service have access to.

Policy Advisor Output Guide:

STATUS = The status of the identity -> service reachability. Will be OKAY or ERROR.

ID = identity name

ID ROUTERS = number of routers accessible to the identity via edge router policies.

- See edge router policies for an identity: ziti edge controller list identity edge-router-policies <identity>

SVC = service name

SVC ROUTERS = number of routers accessible to the service via service edge router policies.

- See service edge router policies for a service with: ziti edge controller list service service-edge-router-policies <service>

ONLINE COMMON ROUTERS = number of routers the identity and service have in common which are online.

COMMON ROUTERS = number of routers (online or offline) the identity and service have in common.

DIAL_OK = indicates if the identity has permission to dial the service.

- See service policies for a service : ziti edge controller list service service-policies <service>

- See service policies for an identity: ziti edge controller list identity service-policies <identity>

BIND_OK = indicates if the identity has permission to bind the service.

ERROR_LIST = if the status is ERROR, error details will be listed on the following lines

Output format: STATUS: ID (ID ROUTERS) -> SVC (SVC ROUTERS) Common Routers: (ONLINE COMMON ROUTERS/COMMON ROUTERS) Dial: DIAL_OK Bind: BIND_OK. ERROR_LIST

ERROR: user.mahasiswa (1) -> webapp (1) Common Routers: (1/1) Dial: N Bind: N

- No access to service. Adjust service policies.

```
ztna@ztna-server:~$
```



```

ztna@ztna-server:~$ ziti edge policy-advisor identities user.dosen webapp

Policy General Guidelines
In order for an identity to dial or bind a service, the following must be true:
- The identity must have access to the service via a service policy of the correct type (dial or bind)
- The identity must have access to at least one on-line edge router via an edge router policy
- The service must have access to at least one on-line edge router via a service edge router policy
- There must be at least one on-line edge router that both the identity and service have access to.

Policy Advisor Output Guide:
STATUS = The status of the identity -> service reachability. Will be OKAY or ERROR.
ID = identity name
ID ROUTERS = number of routers accessible to the identity via edge router policies.
- See edge router policies for an identity: ziti edge controller list identity edge-router-policies <identity>
SVC = service name
SVC ROUTERS = number of routers accessible to the service via service edge router policies.
- See service edge router policies for a service with: ziti edge controller list service service-edge-router-policies <service>
ONLINE COMMON ROUTERS = number of routers the identity and service have in common which are online.
COMMON ROUTERS = number of routers (online or offline) the identity and service have in common.
DIAL_OK = indicates if the identity has permission to dial the service.
- See service policies for a service : ziti edge controller list service service-policies <service>
- See service policies for an identity: ziti edge controller list identity service-policies <identity>
BIND_OK = indicates if the identity has permission to bind the service.
ERROR_LIST = if the status is ERROR, error details will be listed on the following lines

Output format: STATUS: ID (ID ROUTERS) -> SVC (SVC ROUTERS) Common Routers: (ONLINE COMMON ROUTERS/Common Routers) Dial: DIAL_OK Bind: BIND_OK. ERROR_LIST
-----
OKAY : user.dosen (1) -> webapp (1) Common Routers: (1/1) Dial: Y Bind: N

ztna@ztna-server:~$

```

```

ztna@ztna-server:~$ ziti edge policy-advisor identities user.admin webapp

Policy General Guidelines
In order for an identity to dial or bind a service, the following must be true:
- The identity must have access to the service via a service policy of the correct type (dial or bind)
- The identity must have access to at least one on-line edge router via an edge router policy
- The service must have access to at least one on-line edge router via a service edge router policy
- There must be at least one on-line edge router that both the identity and service have access to.

Policy Advisor Output Guide:
STATUS = The status of the identity -> service reachability. Will be OKAY or ERROR.
ID = identity name
ID ROUTERS = number of routers accessible to the identity via edge router policies.
- See edge router policies for an identity: ziti edge controller list identity edge-router-policies <identity>
SVC = service name
SVC ROUTERS = number of routers accessible to the service via service edge router policies.
- See service edge router policies for a service with: ziti edge controller list service service-edge-router-policies <service>
ONLINE COMMON ROUTERS = number of routers the identity and service have in common which are online.
COMMON ROUTERS = number of routers (online or offline) the identity and service have in common.
DIAL_OK = indicates if the identity has permission to dial the service.
- See service policies for a service : ziti edge controller list service service-policies <service>
- See service policies for an identity: ziti edge controller list identity service-policies <identity>
BIND_OK = indicates if the identity has permission to bind the service.
ERROR_LIST = if the status is ERROR, error details will be listed on the following lines

Output format: STATUS: ID (ID ROUTERS) -> SVC (SVC ROUTERS) Common Routers: (ONLINE COMMON ROUTERS/Common Routers) Dial: DIAL_OK Bind: BIND_OK. ERROR_LIST
-----
OKAY : user.admin (1) -> webapp (1) Common Routers: (1/1) Dial: Y Bind: N

ztna@ztna-server:~$

```

Masalah

Service intercepts (webapp, ssh, db) sudah aktif di client VM, namun DNS resolver edge router mengembalikan status REFUSED untuk query domain .ziti.

5. Jawaban Pertanyaan Analisis

- Jelaskan mengapa arsitektur ini disebut identity-driven, bukan network-driven. Bagaimana ini berbeda dari VPN tradisional? Jawaban: Arsitektur ini bersifat identity-driven karena keputusan akses didasarkan pada identitas kriptografis (JWT claims, groups/roles dari Keycloak), bukan lokasi jaringan. Setiap request dievaluasi dua tahap: "Siapa Anda?" melalui authentication via Keycloak, kemudian

“Apa yang Anda boleh akses?” melalui authorization via Ziti policies berdasarkan group/role. Perbedaan dengan VPN tradisional: VPN mempercayai network segment – sekali terhubung ke VPN, pengguna mendapat akses luas ke subnet internal. Zero Trust tidak pernah mempercayai lokasi jaringan; setiap request diverifikasi ulang berdasarkan identity dan policy.

- Authentication menjawab pertanyaan apa? Authorization menjawab pertanyaan apa? Berikan satu contoh konkret dari implementasi Anda. Jawaban: Authentication (AuthN): “Siapa Anda?” – Keycloak memverifikasi kredensial (password, TOTP, WebAuthn) dan menghasilkan JWT token berisi claims (sub, groups). Authorization (AuthZ): “Apa yang Anda boleh lakukan?” – Ziti Controller mengevaluasi service policies, mencocokkan identity attribute (#dosen) dengan service role (@ssh, @webapp). Contoh: dosen login dengan password + TOTP → Keycloak menerbitkan JWT dengan group dosen → Ziti policy dial.dsn mencocokkan #dosen → dosen diizinkan dial @ssh dan @webapp.
- Mengapa Admin membutuhkan 3 lapis autentikasi sementara Mahasiswa cukup 1? Kaitkan dengan riskbased authentication dan least privilege. Jawaban: Admin: akses tertinggi (DB, SSH, Web App) → risiko paling tinggi jika kompromi → membutuhkan 3 faktor (Password + TOTP + Passkey/WebAuthn). Dosen: akses menengah (SSH, Web App) → risiko medium → 2 faktor (Password + TOTP). Mahasiswa: akses terbatas (Web App saja) → risiko rendah → 1 faktor (Password). Prinsip least privilege memberikan akses minimum yang diperlukan, sementara risk-based authentication menyelaraskan kekuatan autentikasi dengan sensitivitas resource dan dampak kompromi.
- Pada skenario #6, jelaskan secara teknis mengapa akses langsung by-IP gagal meski satu subnet. Di titik mana request diblokir? Jawaban: Request diblokir pada dua lapisan: Host Network Stack (Socket Bind): layanan

(webapp:80, ssh:22, db:3306) hanya bind ke 127.0.0.1, tidak listen pada interface 192.168.234.101 dan Firewall (UFW): default deny incoming, hanya mengizinkan koneksi dari 127.0.0.1 ke port layanan. Meski klien dan VM1 berada pada subnet yang sama (192.168.234.0/24), request ke 192.168.234.101:80/22 tetap diblokir di firewall (layer 3/4) dan service bind (layer 7) – membuktikan bahwa dalam Zero Trust, lokasi jaringan tidak sama dengan trust.

- Jika Keycloak down, apa dampaknya terhadap sesi yang sudah established vs percobaan akses baru? Apa artinya bagi continuous verification? Jawaban: Sesi established (Ziti data plane): tetap berjalan karena data plane terpisah dari control plane; sesi mTLS antara client, edge router, dan controller sudah ter-establish. Akses baru / re-authorization: gagal karena Ziti controller tidak dapat memvalidasi JWT baru maupun refresh token dari Keycloak, sehingga policy advisor tidak dapat melakukan evaluasi. Arti bagi continuous verification: setiap request seharusnya diverifikasi ulang (validasi token + evaluasi policy), bukan hanya saat login. Ketika Keycloak down, tidak ada token baru yang dapat diterbitkan sehingga akses baru diblokir, namun sesi yang sudah berjalan tidak terputus karena independensi data plane.
- Apa risiko menempatkan Keycloak, Ziti Controller, Edge Router, dan resource dalam satu VM? Bagaimana Anda memisahkannya jika diberi lebih dari 4 VM? Jawaban: Risiko: Single Point of Failure (SPOF): satu VM down menyebabkan seluruh ZTNA down, Blast radius besar: kompromi satu service dapat memberi akses ke seluruh komponen lain, Tidak ada separation of duties: admin Keycloak, admin Ziti, dan admin OS berada pada pihak yang sama.
Skema pemisahan bila tersedia lebih dari 4 VM:

VM	Komponen
VM1	Keycloak (Identity Provider)

VM	Komponen
VM2	Ziti Controller
VM3	Ziti Edge Router
VM4	Web App + SSH + DB
VM5+	Client VMs

- Jika ditambahkan resource dengan sensitivitas lebih tinggi dari SSH (misal database berisi data pribadi), lapisan tambahan apa yang diperlukan? Jawaban: ABAC (Attribute-Based Access Control): policy berdasarkan atribut dinamis seperti waktu, lokasi, dan device posture, Encryption-at-rest: AES-256 untuk database dan TLS 1.3 untuk data in transit, Audit Logging & SIEM: centralized logging (rsyslog/ELK) dengan alerting terhadap anomali, Session Recording: merekam sesi SSH/DB untuk keperluan forensik, Just-in-Time Access: akses temporer dengan approval workflow, Data Loss Prevention (DLP): memantau dan memblokir eksfiltrasi data sensitif.
- "Never trust, always verify" verifikasi apa saja yang terjadi setiap kali seseorang mengakses resource dalam implementasi Anda? Jawaban: Setiap akses resource melalui Ziti melewati verifikasi berlapis: Keycloak Token Validation: verifikasi signature (RS256), pengecekan expiry, validasi audience, dan integritas claims (groups, sub), Ziti Policy Evaluation: mencocokkan identity attributes (#mahasiswa, #dosen, #admin) dengan service roles (@webapp, @ssh, @db) melalui dial/bind policies, mTLS Verification: mutual TLS antara client, edge router, dan controller berbasis identitas sertifikat, Intercept Enforcement: ziti-edge-tunnel memaksa routing melalui overlay network, bukan direct IP, Posture Check (opsional): pengecekan device health, proses yang berjalan, dan versi OS sebelum akses diberikan. Setiap request pada akhirnya

diverifikasi melalui kombinasi Identity + Context + Policy + Cryptography – inilah esensi verifikasi Zero Trust.

6. Kendala & Solusi

- SSH Hardening pada VM1

Masalah: SSH default listen di 0.0.0.0:22 (semua interface)

Solusi:

- Edit /etc/ssh/sshd_config → ListenAddress 127.0.0.1
- Disable ssh.socket systemd socket activation
- Restart ssh service
- Verifikasi: ss -tlnp | grep :22 → hanya 127.0.0.1:22

- Firewall UFW Default Deny

Masalah: Default UFW allow incoming.

Solusi: ufw default deny incoming, ufw default allow outgoing, allow from 127.0.0.1 ke port 80,22,3306,1280,3022,8080,8443, lalu ufw enable.

- DNS Resolver Edge Router REFUSED

Masalah: Service ziti-dns-resolver telah dibuat dengan intercept/host config, policy bind/dial telah dibuat, dan log edge router menunjukkan hosting server_address[udp:100.64.0.2:53], namun query DNS mengembalikan REFUSED.

Percobaan Solusi:

- Menambahkan CAP_NET_BIND_SERVICE ke systemd service
- Restart ziti-edge-tunnel service di VM1
- Masih belum teratasi – known issue pada edge router v1.6.19

- Keycloak OIDC Integration

Masalah: Ziti controller perlu diintegrasikan dengan Keycloak sebagai external JWT/OIDC provider.

Solusi:

- Membuat client ziti-client di Keycloak realm mbc-lab dengan redirect URIs * dan web origins *
- Memperbarui /opt/ziti-home/ctrl.yaml dengan menambahkan section identityProviders
- Restart ziti-quickstart service

- VM3 & VM4 SSH Access

Masalah: Password user dosen (VM3) dan admin (VM4) tidak diketahui.

Solusi: Akses melalui console VMware untuk reset password, atau setup SSH key dari VM1.

7. Kesimpulan

Implementasi Zero Trust Architecture dengan Keycloak & OpenZiti telah berhasil diimplementasikan dengan capaian sebagai berikut:

Capaian	Status
Infrastructure (4 VM, Network, SSH, Firewall)	Complete
Keycloak IdP (Realm, Users, Groups, MFA, OIDC)	Complete
OpenZiti Controller/Router (Quickstart, OIDC)	Complete
Services & Policies (4 services, 7 policies)	Complete
Identities Enrollment (4 identities)	Complete
Test #6: Direct IP Blocked	PASS
Test #7: Policy Revocation	PASS
Test #1-5 (MFA/AuthZ)	Blocked by DNS Resolver

8. Lampiran

Lampiran A: File Konfigurasi:

- keycloak-realm.json – Full Keycloak realm
- ziti-policies.txt – Ziti service policies, services, configs, identities, auth policies, enrollments
- README.md – Dokumentasi teknis lengkap

Lampiran B: Kredensial

Service	Username	Password
Keycloak Admin	admin	Admin123!
Ziti Controller	admin	admin
VM1 (ztna)	ztna	SSH key

Service	Username	Password
VM2 (mahasiswa)	mahasiswa	ilyas528527
Keycloak Users	mhs1 / dsn1 / adm1 / gst1	Admin123!

Lampiran C: Video Demo

Link:

https://drive.google.com/file/d/15wVFFwSPslvbjBsF0i6K8APwheWDH-W2/view?usp=drive_link